QCM **TEST**

Part I (For Grades F to E)
DD2395 Computer Security
Exam 2020-01-10, 08.00 – 11.00

This is a closed-book exam, no material (books, articles, laptops, phones, or any other electronic devices, etc.) permitted. Questions using the sign ♣ may have zero, one or several true statements in that category. The option None of these answers are correct *exists to detect the difference between a question with no true statements and one that has not been answered. All other options (statements) are graded individually, i.e., whether you correctly identified a statement as true (by filling in the box) or false (by leaving the box empty).*
Mark all true statements on the separate answer sheet by COMPLETELY FILLING in the corresponding box like this: ■. Hand in your exam sorted like this: cover page, Part I: the multiple-choice answer sheet, Part II written responses.

Question 1 ♣ Concepts, CIA

A The main security properties (CIA) are confidentiality, integrity, and accountability.

■ When system resources get corrupted, that results in a loss of integrity.

■ A valid way of interpreting the principle of complete mediation is that there should not be a way around any security checks.

D *None of these answers are correct.*

Question 2 ♣ Authentication.

■ Authentication can be done by proving something you know (e.g. password), something you have (e.g. access card), something you are or do (e.g. biometrics), your location, or several of these factors together.

B As long as a chosen password is not an actual word (e.g., because it contains numbers or special characters), it is safe from an offline dictionary attack.

■ Kerberos provides mutual authentication between a user and a server, i.e., not only is the user authenticated to the server but the user can be sure that the server is authentic as well.

D *None of these answers are correct.*

Question 3 ♣ Cryptography

A Secure hash functions with variable output length offer better resistance against collisions.

B Message authentication protects against an attacker between the sender and the receiver that wants to read the message.

■ The requirements for public-key (asymmetric) cryptography include that it must not be feasible to compute the private key from the corresponding public key or to infer the message given the public key (used for encryption) and the ciphertext.

D *None of these answers are correct.*

Question 4 ♣ Memory safety

■ Stack canaries are mainly used to detect corruptions of return addresses.

B A heap overflow cannot be used to alter the control flow of a program.

■ Executable address space protection prevents code injection by making code non-writable and data non-executable.

D *None of these answers are correct.*

Question 5 ♣ Malware

■ An **encrypting malware** is a malware that uses encryption to make the binary of each infection unique.

B If a ransomware uses **asymmetric encryption**, then it is possible to recover the encrypted files by extracting the encryption key from the malware memory while the malware is running.

C A **secure** mechanism to detect malware is to execute unknown applications on your own computer and periodically inspect the application binary.

D *None of these answers are correct.*

Question 6 ♣ Denial of Service

A Ingress filtering consists of the router **closest** to the victim dropping all packets coming from spoofed IPs

■ A DOS can be performed by exploiting bugs of a remote program and crafting a specific input that leads the victim program to fail.

C In a TCP/IP SYN spoof attack, the attacker primarily exhausts the network bandwidth of the victim.

D *None of these answers are correct.*

Question 7 ♣ System security

A Return Oriented Programming (ROP) and Jump Oriented Programming (JOP) are ineffective if code injection is prevented.

■ Guard Pages are used to detect buffer overflows and buffer over-reads.

■ Address Space Layout Randomization consists of randomizing the positions of the stack, heap, and code, hence making it difficult for an attacker to predict effects of memory errors such as buffer overflows.

D *None of these answers are correct.*

Question 8 ♣ Access Control

A In Unix, permissions are grouped into owner (whose file it is), user (who currently is using the file), and world (everyone else).

■ An access control matrix can be decomposed into access control lists (per object, who can do what to them) and capabilities (per subject, what can they do to which object)

■ Access control is about authorization and needs authentication so that the authorization is meaningful.

D *None of these answers are correct.*

Question 9 ♣ Intrusion Detection, Firewalls

■ Signature-based intrusion detection can only detect intrusions that are already identified as such in the IDS.

■ Firewalls may not fully protect against internal threats.

■ Intrusion detection necessarily results in false positives or negatives.

D *None of these answers are correct.*

Question 10 ♣ Side-channels

- [A] A side-channel attack consists of injecting faults into a system (i.e. using electromagnetic waves).
- [B] Flushing caches is sufficient to prevent attacks that measure execution time of the victim.
- [■] Constant-time execution prevents leakage via side channels by making the control flow and memory accesses being not-dependent on secret variables.
- [D] *None of these answers are correct.*

Question 11 ♣ Privacy

- [■] Privacy-enhancing technologies aim to provide properties such as anonymity, unlinkability, and deniability.
- [■] Privacy concerns not only the data itself (e.g., contents of files or messages) but also metadata, meaning data about the data.
- [C] *None of these answers are correct.*

Question 12 ♣ Web Security

- [■] SQL injections are attacker data injected into otherwise legitimate queries (SQL statements) and can be countered by using parameterized queries.
- [B] Cross-site scripting takes advantage of a user being authenticated for a session with a server and makes it look like a transaction was initiated by the authenticated user.
- [C] *None of these answers are correct.*

Question 13 ♣ Social Engineering, Human Factors, Policies

- [■] One strategy of social engineering is to create and then fix a problem.
- [B] If enough technical countermeasures are deployed (e.g., spam filtering, unclickable links in mails), social engineers cannot succeed.
- [C] *None of these answers are correct.*

Part I Answer Sheet

Answers must be given exclusively on this sheet: answers given on the other sheets will be ignored.

0	0	0	0
1	1	1	1
2	2	2	2
3	3	3	3
4	4	4	4
5	5	5	5
6	6	6	6
7	7	7	7
8	8	8	8
9	9	9	9

⟵ please encode the last 4 digits of your person number by filling the corresponding boxes and write your first and last names below. For temporary person numbers: If you have a T instead of a digit, fill the box containing zero, i.e., if you mark zero as your first of the last four digits of your person number it is because yours is either zero or T.

Firstname and lastname:

.....

.....

Answers:

Question 1: ☐A ■ ■ ☐D
Question 2: ■ ☐B ■ ☐D
Question 3: ☐A ☐B ■ ☐D
Question 4: ■ ☐B ■ ☐D
Question 5: ■ ☐B ☐C ☐D
Question 6: ☐A ■ ☐C ☐D
Question 7: ☐A ■ ■ ☐D
Question 8: ☐A ■ ■ ☐D
Question 9: ■ ■ ■ ☐D
Question 10: ☐A ☐B ■ ☐D
Question 11: ■ ■ ☐C
Question 12: ■ ☐B ☐C
Question 13: ■ ☐B ☐C